

Section 12 – Risk Register

Prepared: May 27, 2026

This register identifies 12 risks across infrastructure, external dependencies, performance, reliability, security, data integrity, and operations. Risks are scored using custom integer scales (not 0–1, not dollar values).

Scale	Values	Meaning
Impact (1–5)	1 · 2 · 3 · 4 · 5	Negligible · Minor · Moderate · Major · Critical
Likelihood (1–5)	1 · 2 · 3 · 4 · 5	Rare · Unlikely · Possible · Likely · Almost Certain
Risk Score (1–25)	Impact × Likelihood	1–6 Low 7–12 Medium 13–19 High 20–25 Critical

Risk Register

ID	Category	Risk Title	Description	Impact	Like- lihood	Score & Band
R-01	Infrastructure	AWS Lab Credentials Expire Mid-Session	Temporary AWS Academy credentials expire every few hours. A live deployment or demo can fail completely if credentials lapse during SAM deploy, SQS operation, or Secrets Manager access.	4 Major	5 Almost Certain	20 Critical
R-02	External Dependency	OpenAI API Quota Exceeded During Exam Evaluation	The evaluation Lambda calls OpenAI with no quota guard. High concurrent usage or a low-tier API key can trigger rate-limit errors, leaving reps with no coaching result after completing an exam.	4 Major	4 Likely	16 High
R-03	Infrastructure	Cognito User Pool Deleted on CloudFormation Stack Update	Renaming the Cognito resource in template.yaml causes CloudFormation to delete and recreate the User Pool, permanently deleting all user accounts and invalidating all active tokens.	5 Critical	3 Possible	15 High
R-06	External Dependency	OpenAI Model Deprecated or API Schema Change	The backend hardcodes the OpenAI Responses API endpoint and JSON schema. A model deprecation or API version change would silently break issue generation and evaluation without code changes.	4 Major	3 Possible	12 Medium
R-08	Data Integrity	Demo Issues Delivered to Reps Without Manager Awareness	When OpenAI fails during issue generation the backend silently stores demo issues. If the manager does not check the generationWarning field, reps take exams on scripted dummy content without knowing.	3 Moderate	4 Likely	12 Medium
R-12	Security	Refresh Token Exposure Enables Long-Lived Session Hijack	Refresh tokens are valid for 30 days and are stored in browser local storage without HttpOnly protection. XSS on the frontend or local storage inspection can expose the token to an attacker.	4 Major	3 Possible	12 Medium

ID	Category	Risk Title	Description	Impact	Like- lihood	Score & Band
R-04	Performance	DynamoDB Full-Table Scan Degrades Under Load	The dashboard, persona list, scenario list, and exam scenario list all use Scan. Under heavy load or a large dataset the scan latency can exceed Lambda timeouts and degrade the manager experience.	3 Mode rate	3 Possible	9 Medium
R-07	Security	CORS Wildcard Origin Allows Unauthorized Frontend	The current CORS configuration allows any origin. Any web page can make credentialed calls to the API if it possesses a valid Cognito token, widening the attack surface for token-stealing exploits.	3 Mode rate	3 Possible	9 Medium
R-11	Operations	Manager Archives All Scenarios Before a Scheduled Exam	The archive action has no confirmation guard in the backend. A manager can accidentally archive all published scenarios, making the exam list empty for all reps until scenarios are republished.	4 Major	2 Unlikely	8 Medium
R-05	Reliability	SQS Delayed Message Not Delivered During Exam	If the SQS delivery for an exam issue is late or dropped, the issue will not become visible on time. The pulse endpoint mitigates this but only when polled; issues may still appear late.	3 Mode rate	2 Unlikely	6 Low
R-10	Reliability	Exam Clock Skew Causes Premature or Late Issue Release	Issue release timing is calculated server-side using Lambda clock. Large clock skew between Lambda invocations or between SQS and Lambda can cause issues to be revealed out of order or late.	3 Mode rate	2 Unlikely	6 Low
R-09	Data Integrity	DynamoDB Item Size Limit Exceeded by Large Scenario	All generated issues are stored inside one DynamoDB item on the Scenarios table. At the maximum 20 issues with long messages the item may approach or exceed DynamoDB's 400 KB item size limit.	2 Minor	2 Unlikely	4 Low

Top Risk Mitigation Plan — R-01: AWS Lab Credentials Expire Mid-Session

Risk ID	R-01
Category	Infrastructure
Impact	4 – Major
Likelihood	5 – Almost Certain
Risk Score	20 / 25 → Critical
Owner	DevOps Lead / Project Manager

Description

Temporary AWS Academy credentials expire every few hours. A live deployment or demo can fail completely if credentials lapse during SAM deploy, SQS operation, or Secrets Manager access.

Root Cause

AWS Academy provides temporary STS credentials that expire every 4–8 hours. The project requires these credentials for every SAM deploy, Lambda invocation test, DynamoDB CLI operation, and Secrets Manager rotation. There is no automated refresh mechanism in the repository — the developer must manually copy new credentials before each session.

Impact Detail

If credentials expire during a SAM deployment, CloudFormation may enter a partial update state requiring manual rollback. If they expire during an exam demo, SQS and DynamoDB operations will fail with `AuthorizationError`, ending the exam session abruptly. Any Lambda invocation requiring Secrets Manager (issue generation, evaluation) will also fail, leaving reps without scoring results.

Mitigation — Immediate Actions

- Add a pre-session checklist to the admin guide requiring credential refresh before every lab session.
- Add a startup script (`scripts/check-creds.sh`) that runs `aws sts get-caller-identity` and exits with an error message if credentials are expired or missing.
- Display a credential expiry warning in the README with the exact refresh procedure.

Mitigation — Short-Term Actions

- Wrap the SAM deploy npm script to call `aws sts get-caller-identity` first and abort if it fails.
- Add a GitHub Actions workflow step that validates credentials before any deploy step.
- Store credential refresh instructions as a pinned note in the team project board.

Mitigation — Long-Term Actions

- Migrate from AWS Academy to a dedicated AWS account where long-lived IAM roles with instance profiles eliminate per-session credential rotation entirely.
- Use AWS CLI named profiles with SSO to allow automated token refresh without manual copy-paste.
- Implement CloudWatch alarm on Lambda `AuthorizationError` to alert the team immediately when credentials expire during a session.

Residual Risk After Full Mitigation

Dimension	Before	After	Change
Impact	4 – Major	2 – Minor	↓ -2
Likelihood	5 – Almost Certain	3 – Possible	↓ -2
Risk Score	20 — Critical	6 — Low	↓ -14

Acceptance Criteria

- ✓ Credential check script exists and passes in CI before every deployment.
- ✓ Admin guide section 08 includes the credential refresh checklist.
- ✓ No deployment has failed due to expired credentials in the last 3 consecutive lab sessions.